VULNERABILITY ASSESSMENT AND PENETRATION TESTING REPORT ON METASPLOITABLE2 AND DVWA

1. EXECUTIVE SUMMARY

This assessment was carried out in a controlled lab setup using DVWA and Metasploitable to simulate a real-world attack scenario. Initial reconnaissance and scanning exposed multiple weak services and poor security configurations. Web testing revealed exploitable vulnerabilities such as SQL Injection and Cross-Site Scripting, confirming improper input validation and lack of secure coding practices. Further analysis identified outdated and insecure services, including FTP and Telnet, which significantly increased the attack surface.

A critical vulnerability in vsftpd 2.3.4 was successfully exploited using Metasploit, leading to full root-level access on the target system. Post-exploitation activities confirmed complete control by accessing sensitive files like system user data. Additionally, Wireshark traffic analysis showed unencrypted communication, highlighting weak network-level protections. These results clearly indicate that the system can be compromised with minimal effort. Immediate corrective actions such as patching, service hardening, and secure configuration are necessary to reduce exposure and strengthen overall security posture.

CATEGORY	DETAIL
Target IP	192.168.11.129
Operating System	Linux Metasploitable 2.6.24 (Ubuntu)
Testing Period	April 28-29, 2026
Overall Risk	CRITICAL
Critical Findings	14
High Findings	8
Medium Findings	40
Tools Used	Nmap, Metasploit, sqlmap, Burp Suite, OpenVAS

2. INTRODUCTION

This report presents the findings of a structured vulnerability assessment and penetration testing exercise conducted in a controlled lab environment. The primary goal was to identify security weaknesses in both web applications and network services using industry-standard tools. The testing approach focused on practical exploitation to understand real attack scenarios rather than theoretical analysis, ensuring that the results reflect actual risks present in the system.

The assessment covered multiple stages including reconnaissance, scanning, exploitation, and post-exploitation validation. Tools such as Nmap, Burp Suite, sqlmap, OpenVAS, Metasploit, and Wireshark were used to simulate attacker behavior. The outcome of this process provides a clear understanding of how vulnerabilities can be leveraged to gain unauthorized access, along with actionable recommendations to improve the security posture of the target environment.

3. OVERVIEW

- The assessment was conducted on DVWA and Metasploitable within a controlled virtual lab environment to simulate real attack conditions.
- Multiple vulnerabilities were identified across web and network layers, including SQL Injection, Cross-Site Scripting, and insecure exposed services.
- Automated and manual tools such as Nmap, Burp Suite, sqlmap, OpenVAS, and Metasploit were used to ensure comprehensive testing coverage.
- A critical vulnerability (vsftpd 2.3.4 backdoor) was successfully exploited, resulting in full system compromise with root-level access.
- The findings highlight poor configurations, outdated services, and lack of security controls, making the system highly vulnerable to real-world attacks.

4. METHODOLOGY

The assessment followed a structured approach to identify and validate vulnerabilities in the target environment. Initial setup verification ensured connectivity between Kali Linux and the Metasploitable system. Reconnaissance was performed using Nmap to discover active hosts and exposed services. Detailed scanning identified service versions and potential weaknesses. Vulnerability assessment was conducted using OpenVAS, sqlmap, Burp Suite, and OWASP ZAP, confirming issues such as SQL Injection and XSS. Exploitation was performed using Metasploit, successfully gaining root access through the vsftpd backdoor. Post-exploitation

activities included system enumeration and sensitive data access. Evidence integrity was maintained using SHA256 hashing and Wireshark traffic analysis.

5. ENVIRONMENT SETUP AND VALIDATION

A controlled lab environment was established using Kali Linux as the attacker machine and Metasploitable2 as the target system, which also hosted the DVWA application. Both systems were configured within the same virtual network to ensure seamless communication. Network validation was performed by identifying IP addresses and confirming connectivity between systems. This setup ensured that all testing activities could be conducted safely without affecting external systems, providing a reliable environment for vulnerability assessment and exploitation.

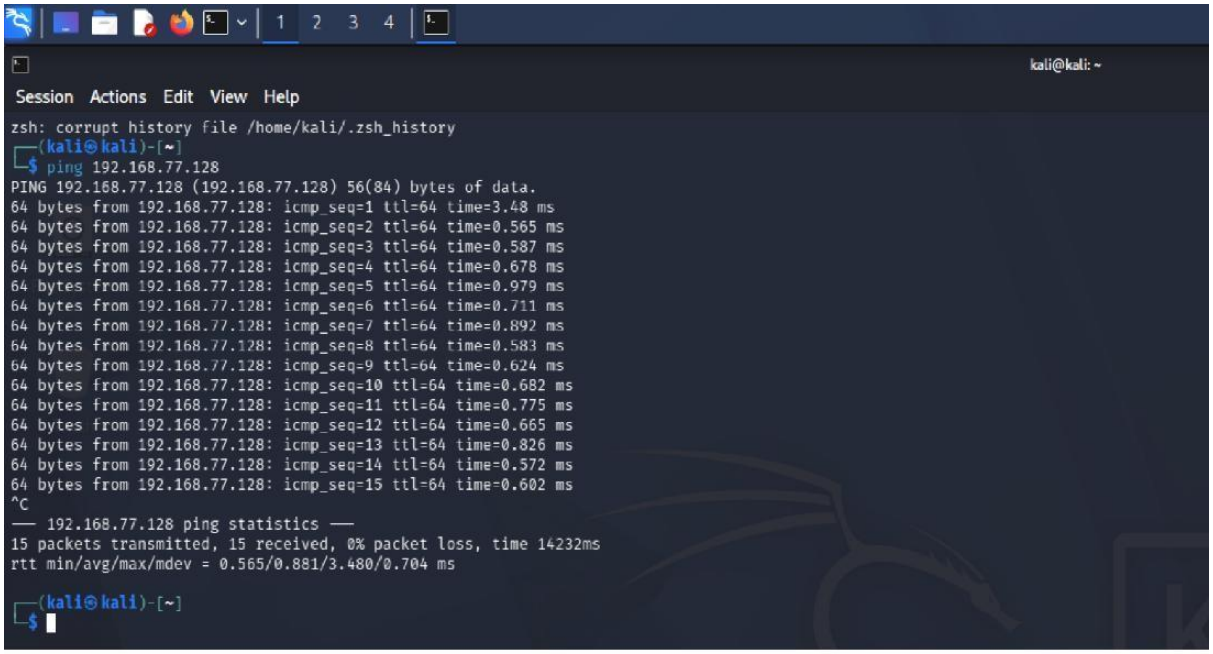

FIGURE 1: *PING VERIFICATION BETWEEN KALI LINUX AND METASPLOITABLE2*

6. RECONNAISSANCE

The reconnaissance phase focused on gathering initial information about the target system to understand its availability and identify potential entry points. This step is essential for mapping the attack surface before performing detailed scanning and exploitation.

Host discovery was performed using Nmap to identify active systems within the network range. The scan confirmed that the target machine (Metasploitable2) was reachable and responding to network requests. This indicated that the system was accessible for further testing.

Command Used

nmap -sn 192.168.11.0/24

Observation

Host	Status	Observation
192.168.11.129	Up	Target system reachable

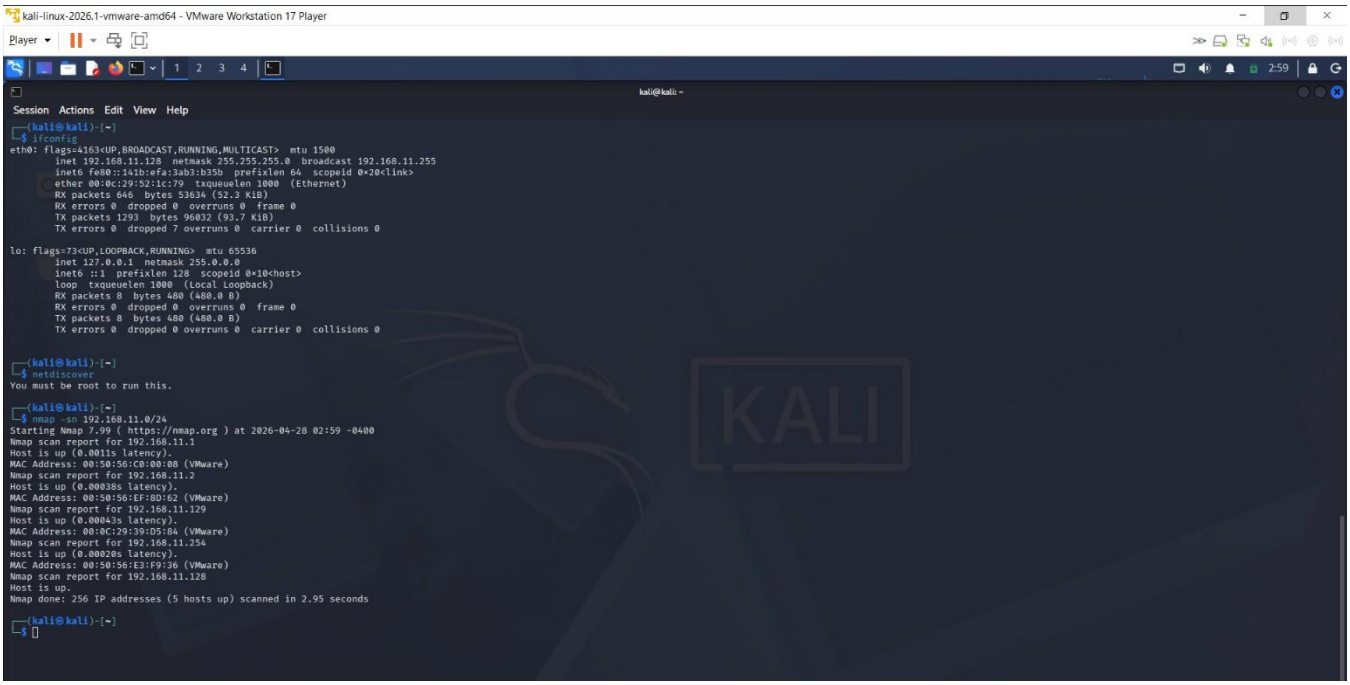

FIGURE 2: *TARGET REACHABILITY VERIFICATION USING NMAP HOST DISCOVERY*

The results confirmed that the target machine was active and exposed within the network. This provided a clear starting point for further scanning and vulnerability identification.

7. SCANNING AND ENUMERATION

After confirming the target system was reachable, detailed scanning and enumeration were performed to identify open ports, running services, and their versions. This phase is critical for

mapping vulnerabilities to specific services and understanding the system's exposure. Nmap service version detection was used to gather detailed information about services running on the target system. The scan revealed multiple open ports associated with outdated and insecure services, increasing the likelihood of exploitation.

COMMAND USED

nmap -sV 192.168.11.129

SERVICE ENUMERATION RESULTS

PORT	SERVICE	VERSION	RISK LEVEL
21	FTP	vsftpd 2.3.4	Critical
22	SSH	OpenSSH	Medium
23	Telnet	Enabled	High
80	HTTP	Apache	High
445	SMB	Samba	High
3306	MySQL	MySQL 5.0	Medium
8180	Tomcat	Apache Tomcat	High

The presence of outdated services such as vsftpd 2.3.4 and Telnet significantly increases the attack surface. These services are known to have publicly available exploits, making them highpriority targets for exploitation in later stages.

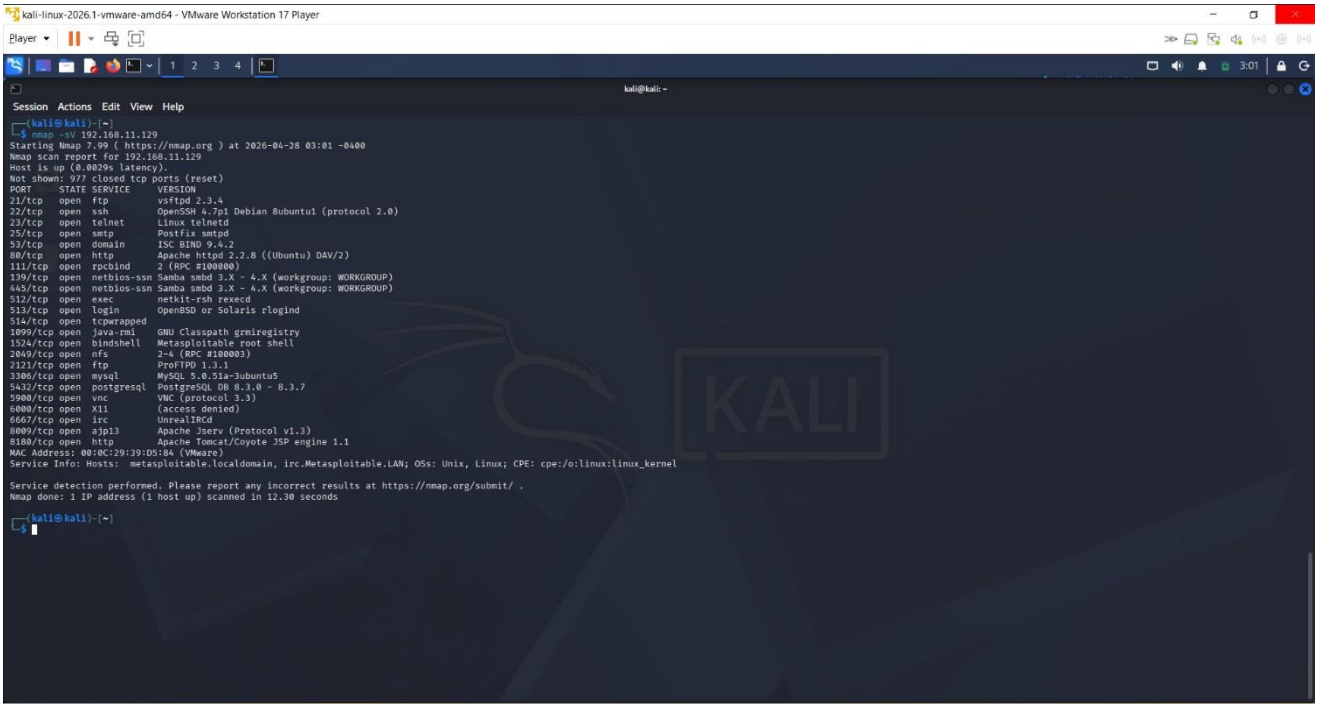

***FIGURE 3**: SERVICE VERSION DETECTION USING NMAP*

8. VULNERABILITY SCANNING

Automated and manual vulnerability assessment techniques were used to identify security weaknesses in both network services and the web application. Multiple tools were used to ensure accurate detection and validation of vulnerabilities.

OpenVAS was used to perform automated vulnerability scanning on the target system. The scan identified multiple critical, high, and medium severity vulnerabilities, including outdated services and insecure configurations. The maximum CVSS score observed was 10.0, indicating highly exploitable vulnerabilities.

Web application testing was performed on DVWA using sqlmap and Burp Suite. SQL Injection was confirmed through automated database enumeration using sqlmap. Reflected Cross-Site Scripting (XSS) was validated through manual payload execution. Burp Suite interception revealed improper session handling and lack of input validation.

TOOLS USED

- OpenVAS
- sqlmap

- Burp Suite
- OWASP ZAP

VULNERABILITY SUMMARY

VULNERABILITY	TOOL USED	SEVERITY
SQL Injection	sqlmap	Critical
XSS	Manual/Burp	Medium
vsftpd Backdoor	OpenVAS/Nmap	Critical
Missing Security Headers	ZAP	Medium
Outdated Services	OpenVAS	High

OBSERVATION

The vulnerability scanning phase confirmed that the target system contains multiple exploitable weaknesses across different layers. The presence of critical vulnerabilities such as SQL Injection and the vsftpd backdoor indicates a high risk of system compromise.

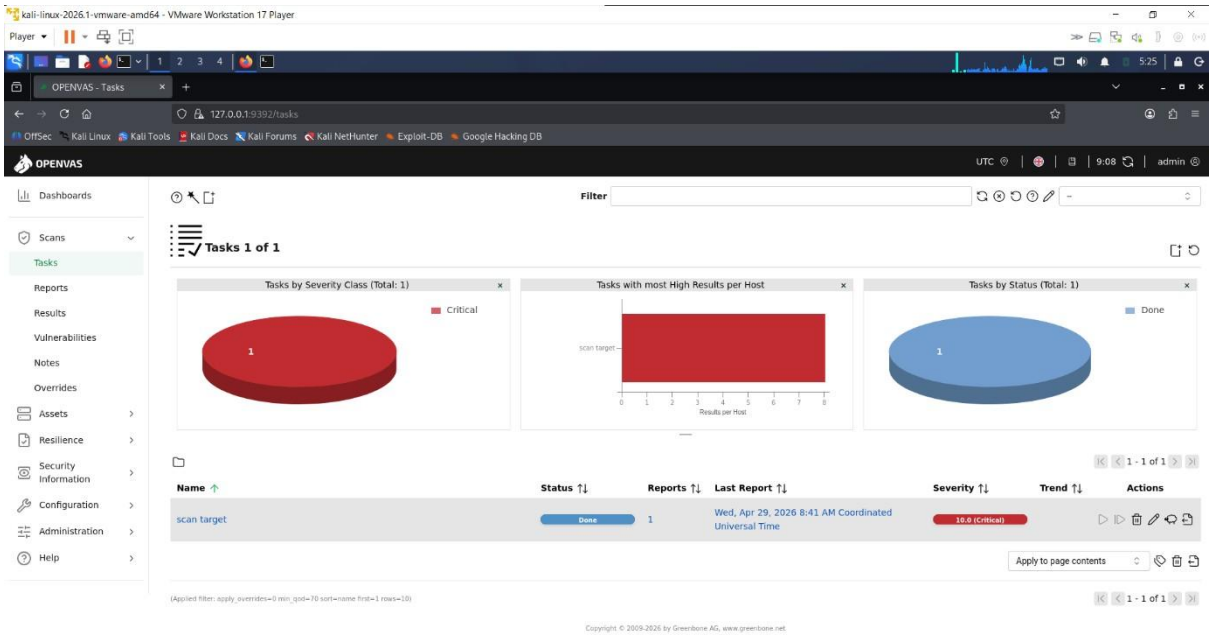

FIGURE 4: *OPENVAS VULNERABILITY SCAN DASHBOARD*

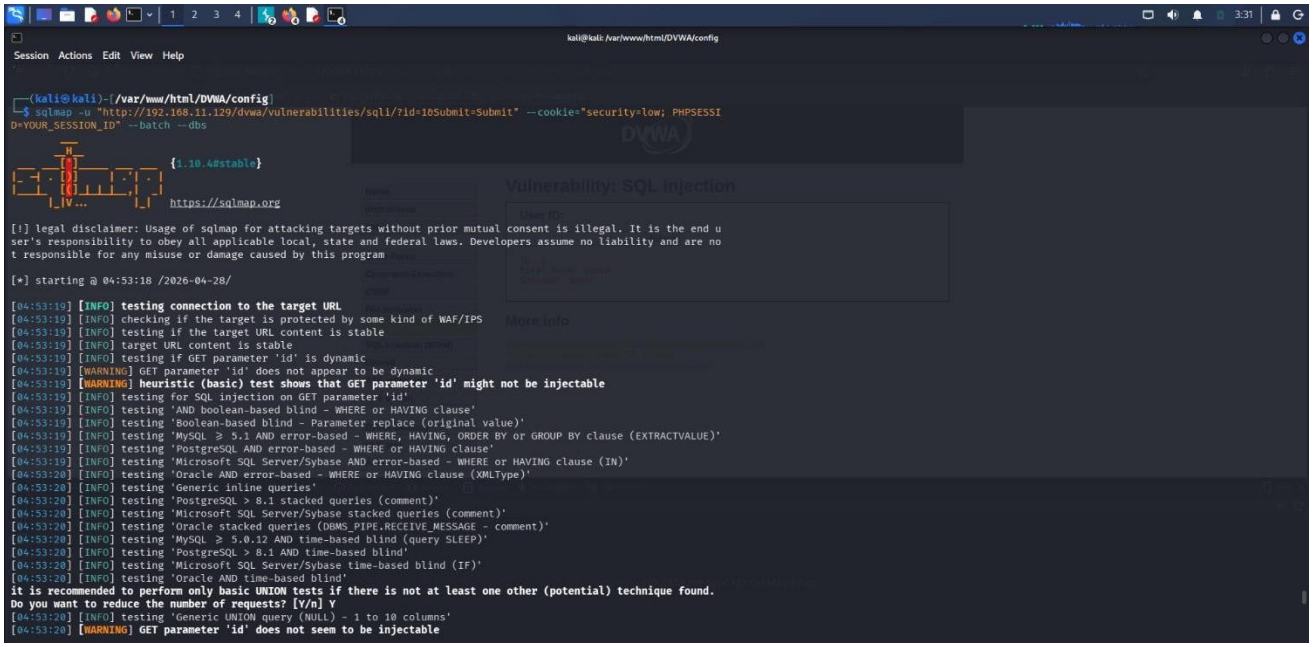

FIGURE 5: *SQL INJECTION EXPLOITATION USING SQLMAP*

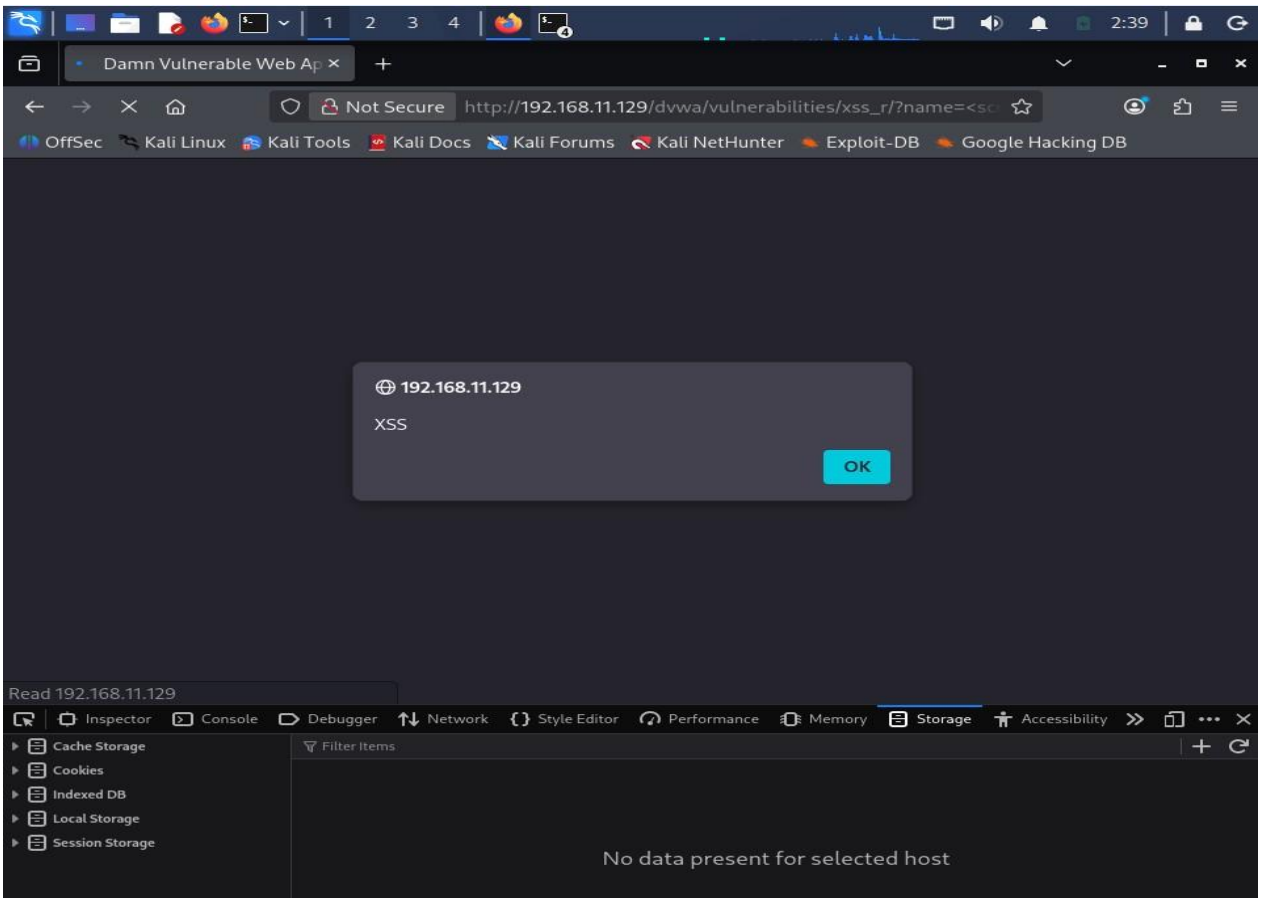

FIGURE 6: *REFLECTED CROSS-SITE SCRIPTING (XSS) EXECUTION IN DVWA*

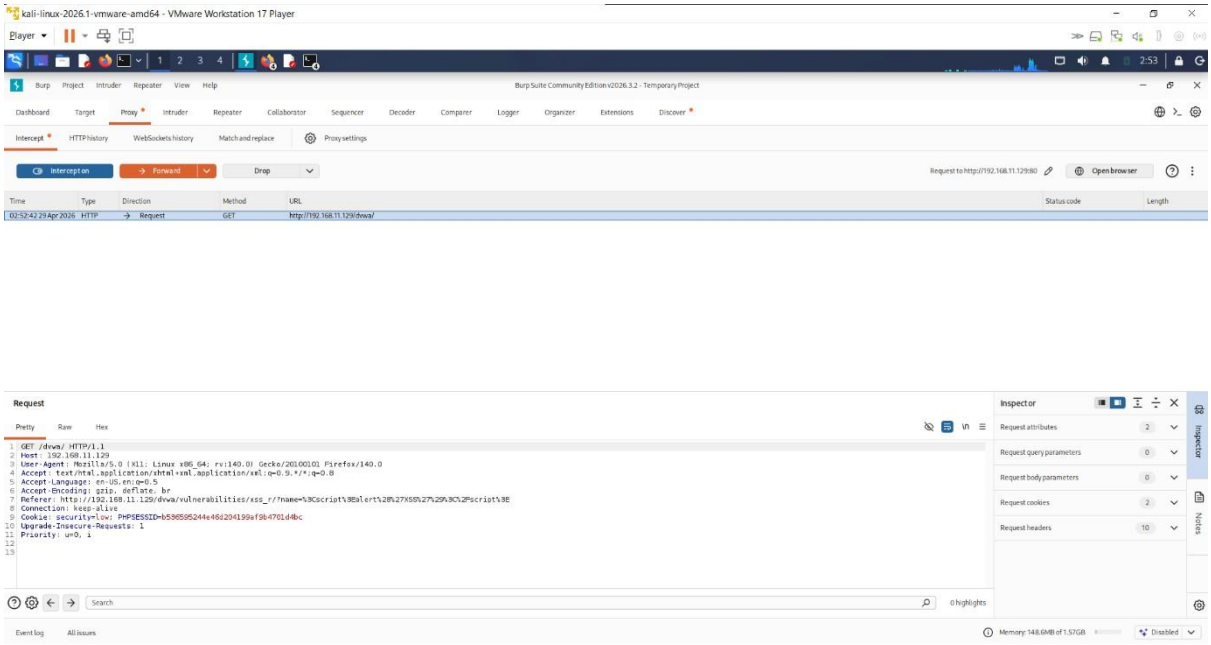

FIGURE 7: *HTTP REQUEST INTERCEPTION USING BURP SUITE PROXY*

9. RISK ASSESSMENT

After completing vulnerability scanning and exploitation, the identified issues were analyzed based on their severity, exploitability, and real-world impact on the target system. The risk assessment helps in prioritizing vulnerabilities and understanding their potential consequences. The most critical vulnerability identified was the **vsftpd 2.3.4 backdoor**, which allowed successful exploitation and resulted in root-level access. This confirms that the system can be completely compromised. Web vulnerabilities such as SQL Injection and XSS further increase the risk by exposing sensitive data and enabling unauthorized actions.

CVSS RISK TABLE

VULNERABILITY	CVSS SCORE	SEVERITY	IMPACT
vsftpd 2.3.4 Backdoor	10.0	Critical	Full system compromise (root access)
SQL Injection	9.1	Critical	Database exposure and data manipulation

Apache Outdated Version	7.5	High	Web exploitation risk
XSS	6.5	Medium	Session hijacking and script execution
Missing Security Headers	5.0	Medium	Increased attack surface

RISK SUMMARY

The assessment clearly shows that the system contains multiple high-risk vulnerabilities that can be easily exploited. The successful exploitation of the FTP service demonstrates that attackers can gain full control over the system. Combined with web application vulnerabilities, the overall security posture is weak and requires immediate attention.

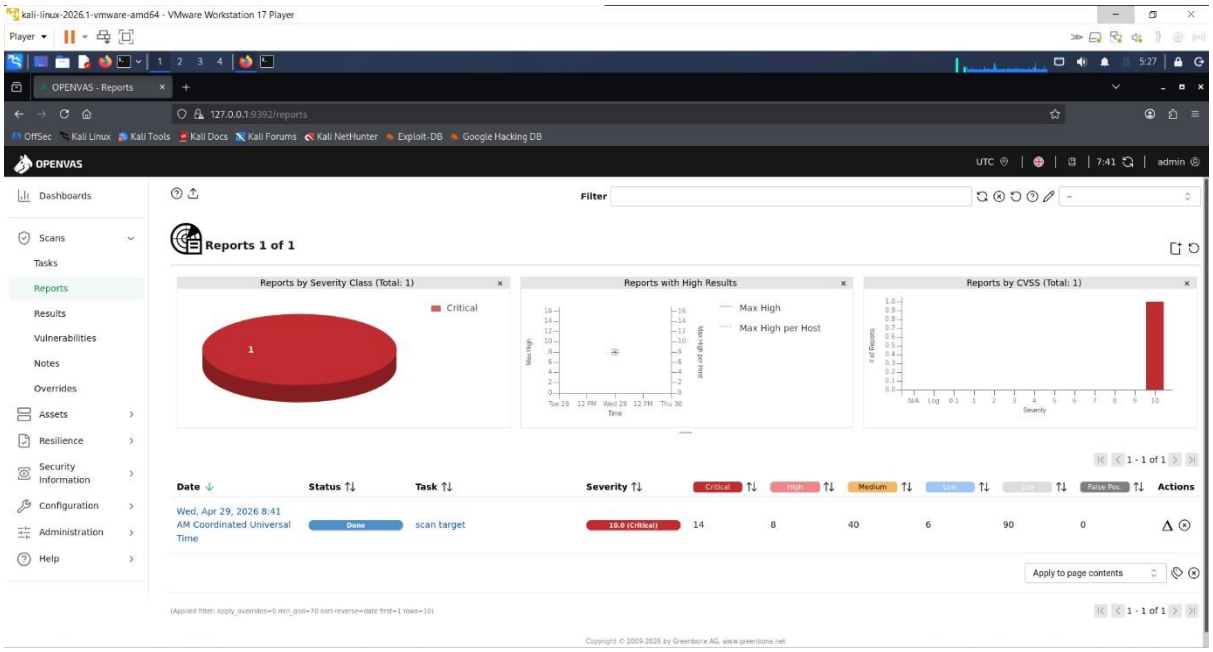

FIGURE 8: *VULNERABILITY SEVERITY DISTRIBUTION AND RISK ANALYSIS*

10. EXPLOITATION

Based on the vulnerabilities identified during scanning, exploitation was performed to validate whether the weaknesses could be used to gain unauthorized access. The most critical

vulnerability selected for exploitation was the **vsftpd 2.3.4 backdoor**, as it is publicly known and has a high CVSS score.

The exploitation was carried out using the Metasploit Framework. By configuring the target IP and selecting the appropriate exploit module, a successful connection was established with the target system. This resulted in gaining unauthorized shell access.

COMMANDS USED

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.11.129

run

EXPLOITATION RESULTS

EXPLOIT NAME	TARGET IP	RESULT	ACCESS LEVEL
vsftpd Backdoor	192.168.11.129	Success	Root Access

The successful exploitation confirms that the vulnerability is real and actively exploitable. It demonstrates that an attacker can gain full control of the system without authentication, making it a critical security risk.

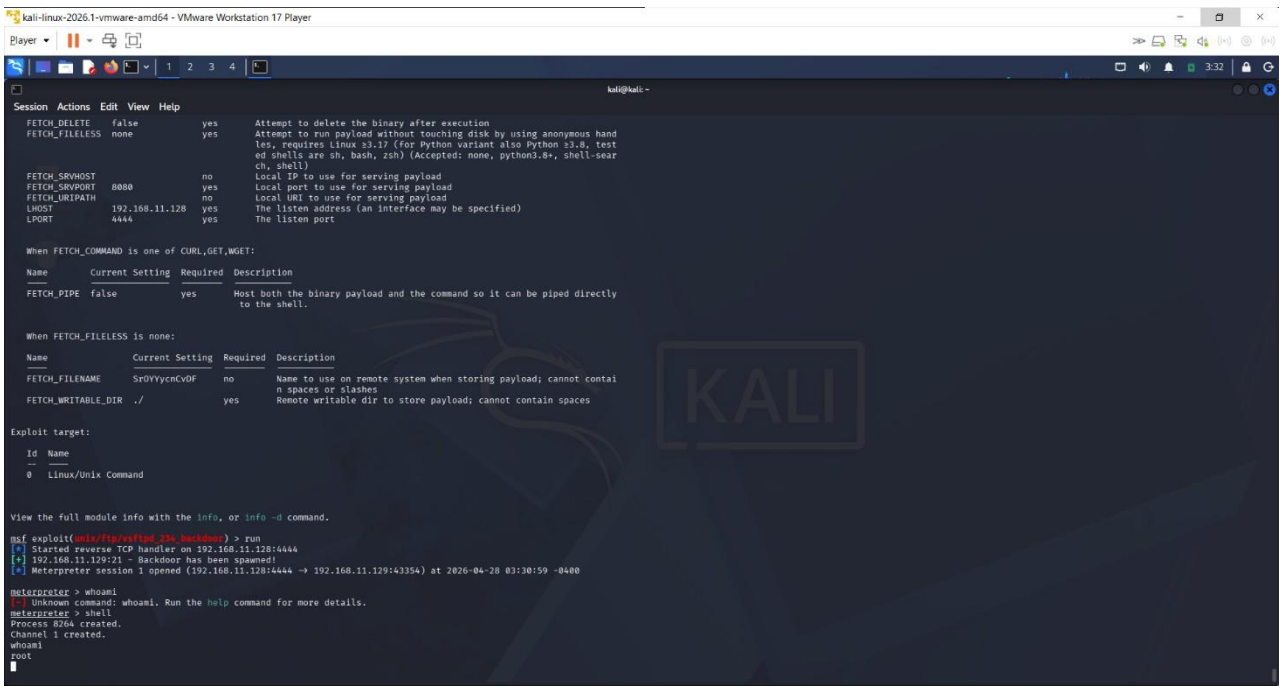

FIGURE 9: *SUCCESSFUL EXPLOITATION OF VSFTPD 2.3.4 USING METASPLOIT*

11. POST-EXPLOITATION

After successful exploitation, post-exploitation activities were performed to validate the level of access and assess the extent of system compromise. These actions help determine the impact of the vulnerability and confirm whether full control over the system has been achieved. Commands were executed to verify user privileges, analyze running processes, and access sensitive system files. The results confirmed that root-level access was obtained, allowing unrestricted control over the target system.

COMMANDS USED

Whoami

uname -a

ps aux

cat /etc/passwd

cat /etc/shadow

POST-EXPLOITATION RESULTS

ACTION	RESULT
User Verification	Root access confirmed
System Information	OS details retrieved
Process Analysis	Running services identified
File Access	/etc/passwd and /etc/shadow accessed
System Control	Full control confirmed

OBSERVATION

The ability to access sensitive files such as /etc/passwd and /etc/shadow confirms complete system compromise. Root-level access allows attackers to modify system configurations, extract credentials, and maintain persistent access. This highlights the severity of the exploited vulnerability and its impact on system security.

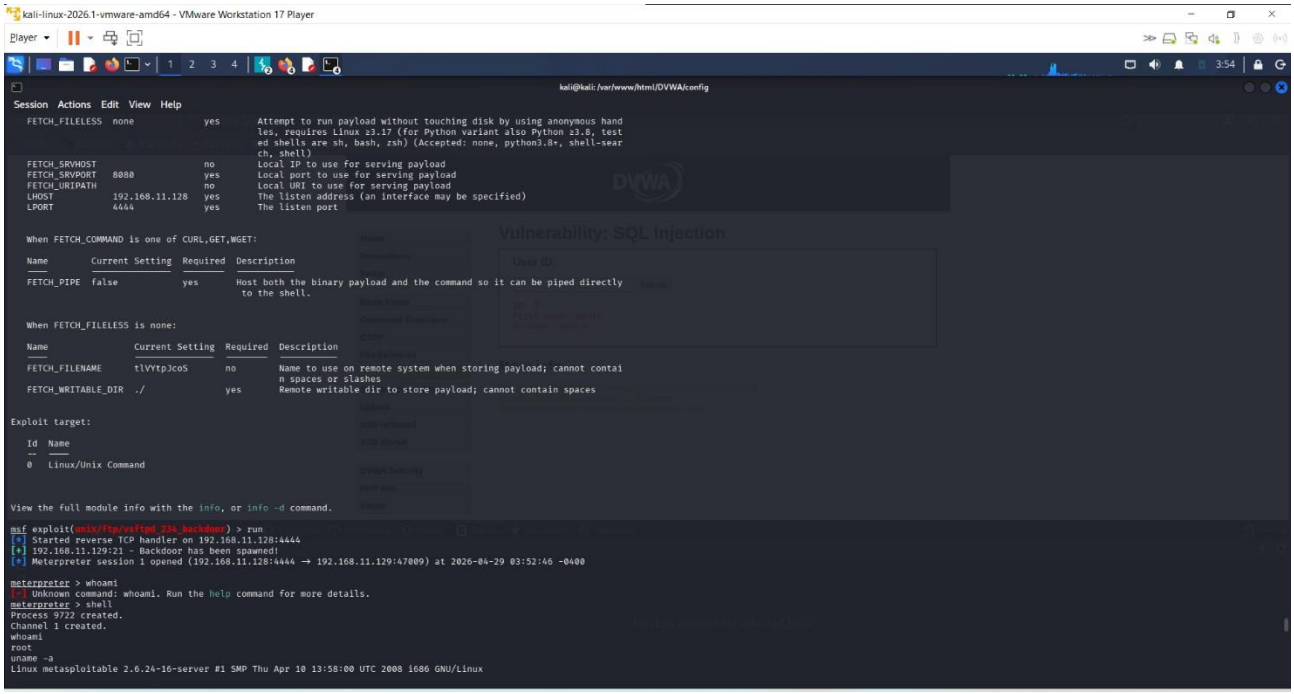

FIGURE 10: *POST-EXPLOITATION SYSTEM ENUMERATION*

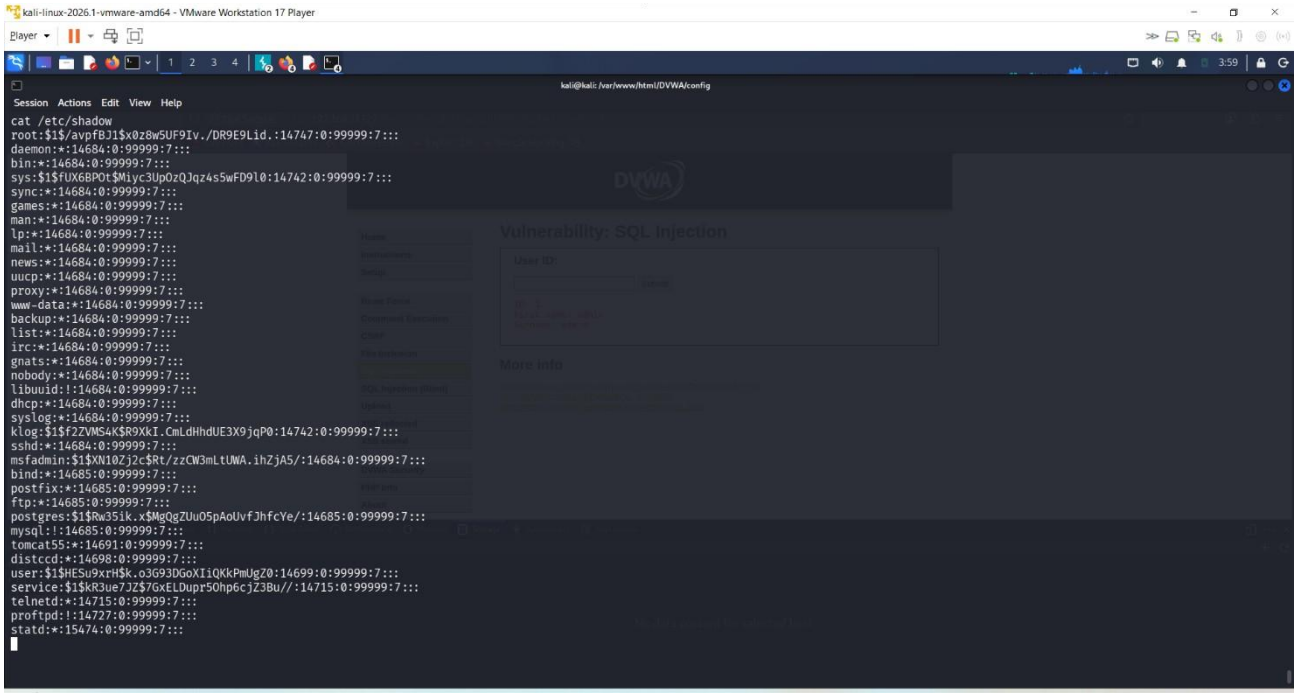

FIGURE 11: *SENSITIVE FILE ACCESS*

12. SERVICE ANALYSIS

During the scanning and enumeration phase, multiple services running on the target system were identified. Several of these services were outdated, misconfigured, or inherently insecure,

increasing the overall attack surface. Each service was analyzed to understand its risk level and potential for exploitation.

KEY SERVICES IDENTIFIED

SERVICE	PORT	VERSION	RISK	DESCRIPTION
FTP	21	vsftpd 2.3.4	Critical	Contains known backdoor vulnerability
SSH	22	OpenSSH	Medium	Secure but depends on configuration
Telnet	23	Enabled	High	Transmits data in plaintext
HTTP	80	Apache	High	Outdated web server with vulnerabilities
SMB	445	Samba	High	Susceptible to remote exploitation
MySQL	3306	MySQL 5.0	Medium	Outdated database service
Tomcat	8180	Apache Tomcat	High	May allow remote code execution

SERVICE OBSERVATIONS

- **FTP (vsftpd 2.3.4):**

  This service contains a built-in backdoor vulnerability, which was successfully exploited to gain root access.

- **Telnet:**

  Telnet is an insecure protocol that transmits credentials in plaintext, making it vulnerable to interception.

- **HTTP (Apache):**

  The web server hosts DVWA and contains vulnerabilities such as SQL Injection and XSS.

- **SMB (Samba):**

  Exposed SMB services can allow unauthorized access and are commonly targeted for exploitation.

- **MySQL:**

Running an outdated version, making it vulnerable to known database attacks.

OBSERVATION

The presence of multiple insecure and outdated services significantly increases the attack surface. These services provide multiple entry points for attackers, making the system highly vulnerable to exploitation if not properly secured.

13. REMEDIATION & MITIGATION

The identified vulnerabilities expose the system to significant security risks, including unauthorized access, sensitive data leakage, and potential full system compromise. Weak input validation, outdated services, and insecure configurations increase the likelihood of successful exploitation. Immediate remediation is essential to minimize these risks and protect system integrity. Strengthening security controls, updating vulnerable components, and enforcing proper authentication mechanisms will reduce exposure. Continuous monitoring and regular vulnerability assessments should be implemented to ensure long-term protection. Addressing these issues promptly will enhance the overall security posture and prevent attackers from leveraging these weaknesses for unauthorized activities or system manipulation.

RECOMMENDED FIXES

VULNERABILITY	RECOMMENDED ACTIONS
SQL Injection	Use parameterized queries and prepared statements. Apply strict input validation and sanitization. Disable detailed database error messages.
Cross-Site Scripting (XSS)	Implement output encoding. Use Content Security Policy (CSP). Validate and sanitize all user inputs.
vsftpd Backdoor (Critical)	Upgrade to a secure version of vsftpd. Disable FTP if not required. Restrict access using firewall rules.
Telnet Service	Disable Telnet completely. Replace with SSH for secure remote access.
SMB Vulnerabilities	Update Samba to the latest version. Disable unnecessary file sharing. Restrict access via firewall.

Weak Authentication & Sessions	Enforce strong password policies. Use secure session management. Enable session timeout and regeneration.
Outdated Services	Regularly update Apache, MySQL, and Tomcat. Apply the latest security patches.

GENERAL SECURITY MEASURES

- Enable firewall (UFW or iptables) to control incoming and outgoing traffic
- Deploy IDS/IPS systems for intrusion detection and prevention
- Perform regular vulnerability scans using tools like OpenVAS
- Disable unnecessary ports and services
- Maintain proper logging and continuous monitoring

VERIFICATION

- After applying remediation:
- Re-run OpenVAS scan
- Verify reduction in:
- Critical vulnerabilities
- High-risk findings

OBSERVATION

The identified vulnerabilities stem from outdated software, insecure configurations, and insufficient input validation. Implementing the recommended controls will significantly reduce the risk of exploitation and improve the overall security posture of the system.

14. CONCLUSION

The VAPT assessment successfully identified multiple vulnerabilities across both network services and the web application layer within the lab environment. Reconnaissance and scanning revealed several exposed and outdated services, while vulnerability assessment confirmed critical weaknesses such as SQL Injection, Cross-Site Scripting, and insecure protocols like FTP and Telnet. The successful

exploitation of the vsftpd 2.3.4 backdoor demonstrated that these vulnerabilities are not theoretical and can be actively used to gain unauthorized access.

Post-exploitation activities confirmed full system compromise by obtaining root-level access and retrieving sensitive files. Network traffic analysis further highlighted insecure communication patterns. These findings emphasize the importance of timely patching, secure configurations, and continuous monitoring. Implementing the recommended remediation measures will significantly reduce the attack surface and improve system resilience against real-world threats.

15. REFERENCES

- Offensive Security. *Metasploitable2 Vulnerable Machine Documentation.* Available at: https://docs.rapid7.com/metasploit/metasploitable-2/
- Nmap Project. *Nmap Network Scanning Documentation.* Available at: https://nmap.org/book/
- OWASP Foundation. *OWASP Top 10 Web Application Security Risks.* Available at: https://owasp.org/www-project-top-ten/
- sqlmap Project. *Automatic SQL Injection Tool Documentation.* Available at: https://sqlmap.org/
- PortSwigger. *Burp Suite Documentation.* Available at: https://portswigger.net/burp
- OWASP ZAP. *Zed Attack Proxy Documentation.* Available at: https://www.zaproxy.org/docs/
- Greenbone. *OpenVAS / Greenbone Vulnerability Management Documentation.* Available at: https://greenbone.github.io/docs/
- Rapid7. *Metasploit Framework Documentation.* Available at: https://docs.metasploit.com/
- Wireshark Foundation. *Wireshark User Guide.* Available at: https://www.wireshark.org/docs/
- MITRE Corporation. *Common Vulnerabilities and Exposures (CVE).* Available at: https://cve.mitre.org/
- FIRST.Org. *Common Vulnerability Scoring System (CVSS v3.1).* Available at: https://www.first.org/cvss/